

Web Attack Risk Prediction

Makine Öğrenmesi ve Açıklanabilir Yapay Zeka ile
Web Saldırı Tespiti ve KVKK Bazlı Maliyet/Fayda Analizi

YÖNETİCİ ÖZETİ RAPORU

Metrik	Değer
Toplam Veri	61.065 HTTP request (4 farklı kaynak)
En İyi Model	XGBoost (F1=0.9321, AUC=0.9919) — GridSearchCV optimize
FN Maliyeti	43.677 TL (KVKK veritabanından Beklenen Değer ile türetilmiş)
Optimal Threshold	0.05 (standart 0.50 yerine)
Threshold Tasarrufu	11.055.885 TL (test seti ölçeğinde)
Yıllık ROI (ALE)	%168
Inference Latency	1.28 ms/request — Near real-time IDS için uygun

1. Problem Tanımı

Web uygulamalarına yönelik siber saldırılar (SQL Injection, XSS, Path Traversal vb.) işletmeler için ciddi finansal ve yasal riskler oluşturmaktadır. KVKK kapsamında veri güvenliği ihlalleri 2025 yılı itibarıyla 13.620.402 TL'ye kadar idari para cezası ile sonuçlanabilmektedir.

Bu projede 61.065 HTTP request analiz edilerek ML tabanlı saldırı tespit sistemi geliştirilmiş, işletmeye sağlanacak değer KVKK mevzuatı ve ALE (Annual Loss Expectancy) metodolojisi ile kanıtlanmıştır.

2. Veri Kaynakları ve Harmanlama

4 farklı veri kaynağı anlamlı şekilde birleştirilmiştir:

Kaynak	Tür	Boyut	Harmanlama Rolü
CSIC 2010 HTTP	Kaggle CSV	61.065	Ana veri seti: normal ve saldırı HTTP request'leri
Web App Payloads	Kaggle JSONL	455	Saldırı imzaları → regex pattern üretimi
Foospidy Payloads	GitHub	28.569	Kapsamlı saldırı pattern koleksiyonu
Türkiye KVKK	Sentetik	250	KVKK cezaları + ALE maliyet mapping

Harmanlama: Kaynak 2+3'ten regex pattern üretilmiş → Kaynak 1'e uygulanmış → Kaynak 4'ten maliyet merge edilmiştir.

3. Feature Engineering (12 Yeni Özellik)

Siber güvenlik domain bilgisine dayalı 12 feature türetilmiştir. Data leakage önlemek için regex pattern flag'leri modelden çıkarılmıştır:

- request_length, url_length, content_length — Request boyut metrikleri
- special_char_count, digit_count — Saldırı syntax göstergeleri
- entropy_score (Shannon Entropy) — Obfuscated payload tespiti
- encoded_char_ratio — WAF bypass girişimi tespiti
- uppercase_ratio — Encoding manipülasyonu göstergesi
- parameter_count, url_depth, is_post, is_put — Yapısal HTTP özellikleri

4. Modelleme (GridSearchCV Optimize)

Random Forest ve XGBoost modelleri GridSearchCV ile optimize edilmiş, 5-fold Stratified CV ile değerlendirilmiştir:

Model	Accuracy	F1 Score	Precision	AUC-ROC
Random Forest	0.9390	0.9275	0.90	0.9913
XGBoost (Optimize)	0.9433	0.9321	0.91	0.9919

XGBoost en iyi parametreler: learning_rate=0.2, max_depth=8, n_estimators=200

5. Açıklanabilir Yapay Zeka (SHAP)

Model kararları SHAP ile hem global hem bireysel düzeyde açıklanmıştır.

Global Bulgular:

- encoded_char_ratio ve request_length en yüksek SHAP etkisine sahip
- Yüksek entropy → saldırı olasılığı artıyor (obfuscation tespiti)
- uppercase_ratio obfuscation tespitinde kritik rol oynuyor

Bireysel Tahmin Açıklaması (Local Explanation):

Saldırı olarak sınıflandırılan bir örnek request:

- encoded_char_ratio: 0.0081 → SHAP: +0.1018 (↑ Saldırı)
- special_char_count: 5.0 → SHAP: +0.0981 (↑ Saldırı)
- entropy_score: 4.90 → SHAP: +0.0600 (↑ Saldırı)
- digit_count: 10.0 → SHAP: +0.0588 (↑ Saldırı)

SHAP sonuçları siber güvenlik domain bilgisiyle tam tutarlıdır.

6. KVKK Bazlı Maliyet/Fayda Simülasyonu

6.1 Maliyet Matrisi (KVKK Veritabanından Türetilmiş)

Senaryo	Maliyet	Türetim Yöntemi
False Positive	150 TL	Normal kullanıcı bloklanması + destek maliyeti
False Negative	43.677 TL	Ort. olay maliyeti (8.735.389 TL) × ihlale dönüşme olasılığı (%0.5) = Beklenen Değer
True Positive	0 TL	Tasarruf mükerrer sayılmaz; değer “önlenen zarar” olarak hesaplanır

Not: TP=0 TL yaklaşımı mükerrer hesaplamayı (double counting) önler. Tasarruf, “Model Yok” senaryosu ile “ML Model” senaryosu arasındaki mutlak farktan hesaplanır.

6.2 Threshold Optimizasyonu

- Default threshold (0.50): Toplam maliyet 11.464.347 TL
- Optimal threshold (0.05): Toplam maliyet 408.462 TL
- Threshold optimizasyonu ile 11.055.885 TL ek tasarruf

Bu, standart %50 eşiğinin yetersiz olduğunun kanıtıdır. Düşük threshold KVKK ceza riskini minimize eder.

6.3 Yıllık Projeksiyon (ALE — Annual Loss Expectancy)

Test seti sonuçları orta ölçekli bir e-ticaret ortamına (günlük 500K request) yıllık bazda projekte edilmiştir:

Senaryo	Test Seti Maliyeti	ALE ROI
Model Yok	218.952.801 TL	-
Default (t=0.50)	11.464.347 TL	-
ML Model (t=0.05)	408.462 TL	%168

7. Model Inference Performansı

Üretim ortamında kullanılabilirlik için tahmin süresi ölçülmüştür:

Metrik	Değer	Değerlendirme
Ortalama Latency	1.28 ms/request	Near real-time uygun
P99 Latency	1.74 ms/request	SLA uyumlu
Throughput	784 request/saniye	Asenkron IDS için yeterli

Mimari Öneri: Yoğun trafikli ortamlarda model inline değil, asenkron IDS katmanı olarak konumlandırılmalıdır. Trafik WAF'tan geçerken loglar Kafka/RabbitMQ kuyruğuna beslenir, model arka planda near real-time risk skorlaması yapar.

8. Sonuç ve Öneriler

Bu proje, web saldırı tespitinde makine öğrenmesinin teknik, finansal ve yasal değer üretebileceğini göstermiştir.

Yapılanlar:

- 4 farklı veri kaynağı başarıyla harmanlanmıştır
- 12 iş mantığına dayalı feature türetilmiş, data leakage önlenmiştir
- GridSearchCV ile hiperparametre optimizasyonu yapılmıştır
- XGBoost: %94.33 accuracy, F1=0.9321, AUC-ROC=0.9919
- FN maliyeti KVKK veritabanından Beklenen Değer yöntemiyle türetilmiştir
- TP=0 TL ile mükerrer hesaplama (double counting) önlenmiştir
- Threshold optimizasyonu ile 11M TL ek tasarruf kanıtlanmıştır
- ALE bazlı yıllık projeksiyon ile %168 ROI hesaplanmıştır
- SHAP ile global ve local düzeyde açıklama yapılmıştır
- Inference benchmark: 1.28 ms/request — near real-time IDS uyumlu

Öneriler:

- Threshold=0.05 ile deploy edilmesi önerilir (KVKK ceza riskini minimize eder)
- Asenkron IDS mimarisi: WAF → Kafka kuyruk → ML model → dinamik WAF kural güncellemesi
- KVKK uyum sürecinde ML tabanlı IDS kullanımı “veri güvenliği yükümlülüğü” kapsamında gösterilebilir
- Modelin periyodik olarak yeni payload veritabanlarıyla güncellenmesi önerilir

YBS 4. Sınıf — Python ile Veri Bilimi Dönem Sonu Projesi

Kaynaklar: KVKK Madde 18 (2025 güncel tutarlar), IBM Cost of Data Breach Report 2024, OWASP Top 10 2021, NIST SP 800-30 (Risk Assessment)